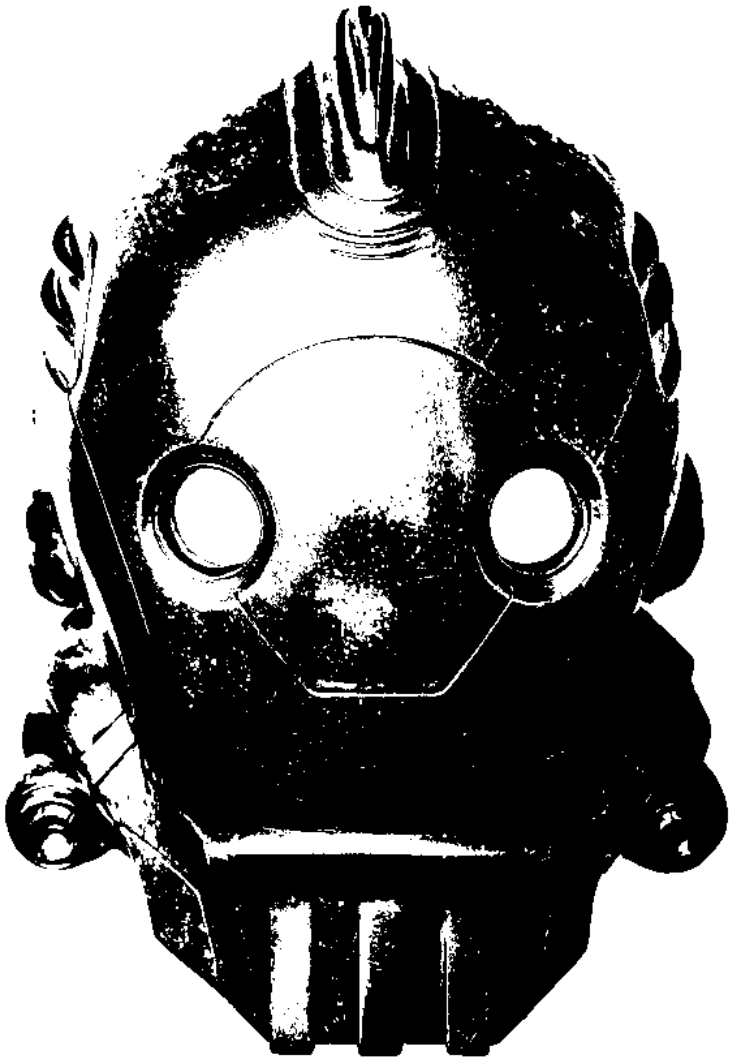
SENTINEL



Por Álex Vidal Rodenas

INDEX

1. Actualización de la Planificación..... 3
1.1 Diagrama de Gantt Final y Desviaciones Reales.....3
1.2. Gestión de Recursos Humanos y Materiales Adicionales..... 4
2. Ejecución de Servicios Avanzados (HA y Monitorización).....4
3. Informe de Hardening y Seguridad..... 5
4. Resultados de Pruebas de Rendimiento..... 7
4.1. Propuestas de Mejora..... 7
5. Gestión de Cambios e Incidencias..... 9
6. Valoración Económica Final..... 10
6.1. Análisis de Gasto Real (Marzo 2026).....11
6.2. Desglose por Servicios.....11
6.3. Conclusión de Viabilidad.....12
Repositorio y Trazabilidad..... 12

1. Actualización de la Planificación

1.1 Diagrama de Gantt Final y Desviaciones Reales

La implementación real sufrió una desviación del **15%** en tiempo debido a retos técnicos imprevistos en la capa de seguridad y observabilidad.

Cronograma de Desviaciones:

Hitos Críticos y Resolución:

- **Conectividad Wazuh-Grafana (Retraso: 3 días):** Incompatibilidad de versiones entre el Indexer y el plugin de OpenSearch (Error 403). Se solucionó actualizando el plugin a v2.0.0 y reconfigurando el binding de red.
- **Despliegue de Loki (Retraso: 1 día):** Fallo de permisos en el directorio WAL. Se corrigió mediante auditoría de permisos a nivel de FS y reestratificación del volumen Docker.
- **Implementación de HAProxy (Adelanto: 2 días):** La simplicidad de la configuración de estadísticas (puerto 8404) permitió validar los *health checks* antes de lo previsto.

A pesar de los retrasos en la capa de monitorización, la fase de Hardening se solapó con la resolución de incidencias, permitiendo finalizar el proyecto dentro del margen de entrega establecido.

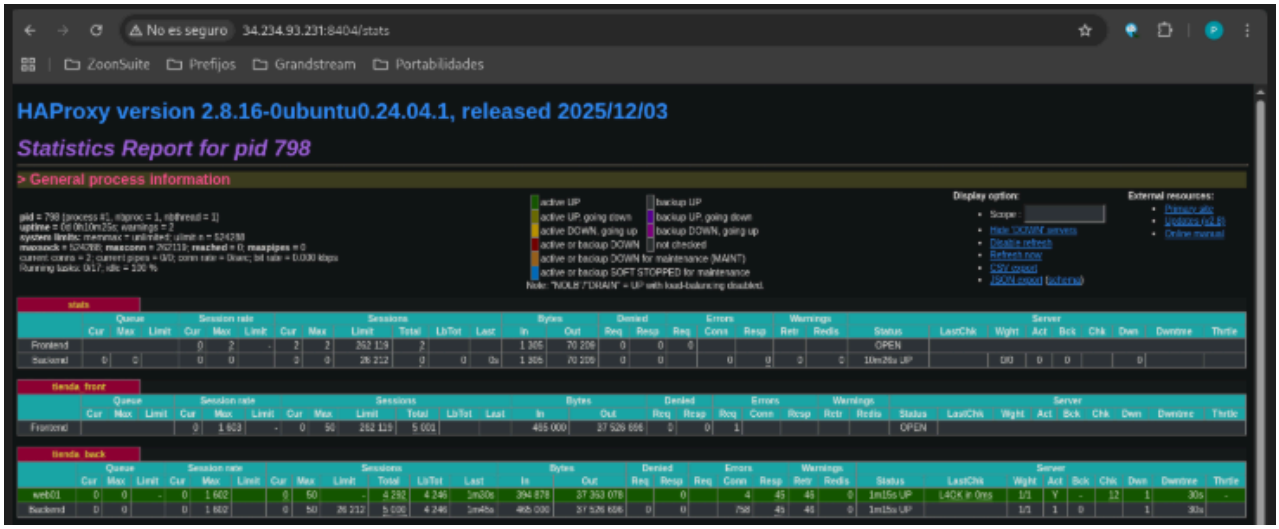
1.2. Gestión de Recursos Humanos y Materiales Adicionales

Al ser un proyecto individual, el esfuerzo se distribuyó en tres roles críticos:

- **Analista de Seguridad (30%)**: Hardening de SSH, MariaDB y auditoría con Wazuh.
- **Arquitecto Cloud/Sistemas (50%)**: Gestión de EC2, HAProxy y stack Docker.
- **HAProxy.pngDesarrollador Full-Stack (20%)**: Securización del código PHP de la tienda.

2. Ejecución de Servicios Avanzados (HA y Monitorización)

Se ha implementado **HAProxy** como puerta de enlace de alta disponibilidad. Toda la telemetría del sistema se centraliza en un **Dashboard de Grafana** diseñado para la toma de decisiones.



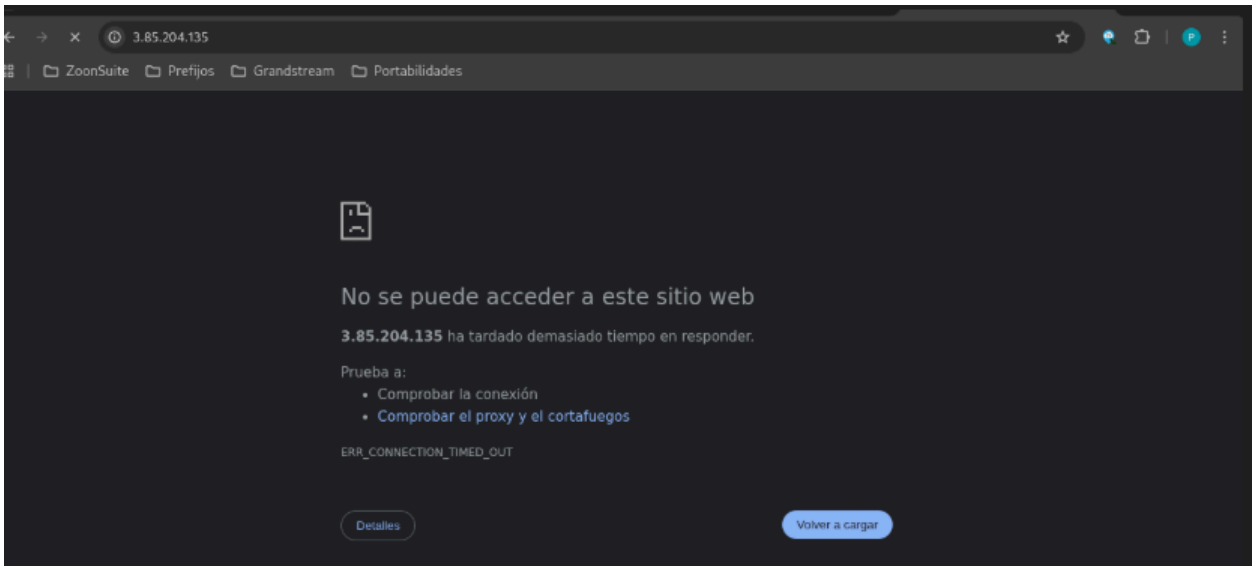
3. Informe de Hardening y Seguridad

Se ha aplicado el principio de **Defensa en Profundidad** mediante las siguientes medidas técnicas:

Dimensión	Medida de Seguridad	Implementación Técnica	Objetivo
Acceso Remoto	**SSH Hardening**	Desactivación de PermitRootLogin y PasswordAuthentication en /etc/ssh/sshd_config.	Impedir ataques de fuerza bruta y asegurar el acceso solo vía llaves .pem.
Red	**Microsegmentación**	Configuración de *Security Groups* para que el Web Server solo acepte tráfico del Balanceador (13.218.124.231).	Ocultar la IP real del servidor de aplicaciones y mitigar ataques directos.
Base de Datos	**Privilegios Mínimos**	Restricción del usuario adminweb a la IP privada del Web Server (10.0.1.250) en MariaDB.	Evitar que un compromiso del balanceador o del manager permita el acceso a la DB.
Servicios	**Reducción de Superficie**	Identificación y desactivación de servicios innecesarios (ej. rpcbind).	Eliminar vectores de ataque por

			servicios en desuso.
Monitorización	**SIEM (Wazuh)**	Agentes en todos los nodos con el módulo Vulnerability Detection (syscollector) habilitado.	Detección inmediata de intrusiones y cambios no autorizados en archivos.
Gestión	**Banner Disuasorio**	Implementación de "SENTINEL Banner" en el acceso por terminal.	Gestión proactiva de parches y detección de CVEs críticos en tiempo real.
Arquitectura	**Aislamiento de Control**	Despliegue del stack de monitorización en una instancia independiente (34.201.102.91).	Garantizar la visibilidad del ataque incluso si el nodo de aplicaciones cae.

Como se observa en la tabla superior, el proceso de hardening no se limitó a una sola capa, sino que aplicó el principio de **Defensa en Profundidad**. La medida más crítica fue el aislamiento del backend, donde el servidor de aplicaciones dejó de ser accesible desde el internet público, forzando todo el tráfico a través del nodo de **HAProxy**. Esta configuración, combinada con la monitorización activa de **Wazuh**, permite que el sistema SENTINEL no solo sea robusto ante ataques externos, sino que sea capaz de auditar internamente cualquier intento de escalada de privilegios.



Prueba de acceso directo fallida a la IP del servidor web (Hardening verificado).

4. Resultados de Pruebas de Rendimiento

Se han realizado pruebas de estrés utilizando Apache Benchmark (ab) sobre la IP pública del Balanceador.

- **Capacidad Máxima:** ~47 peticiones por segundo sostenidas.
- **Cuello de Botella:** Al superar las 50 conexiones concurrentes, se detectó latencia de hasta 800ms.

4.1. Propuestas de Mejora

- **Escalado Horizontal:** Añadir un segundo nodo backend en HAProxy.
- **Caché:** Implementar Redis para reducir carga en MariaDB.

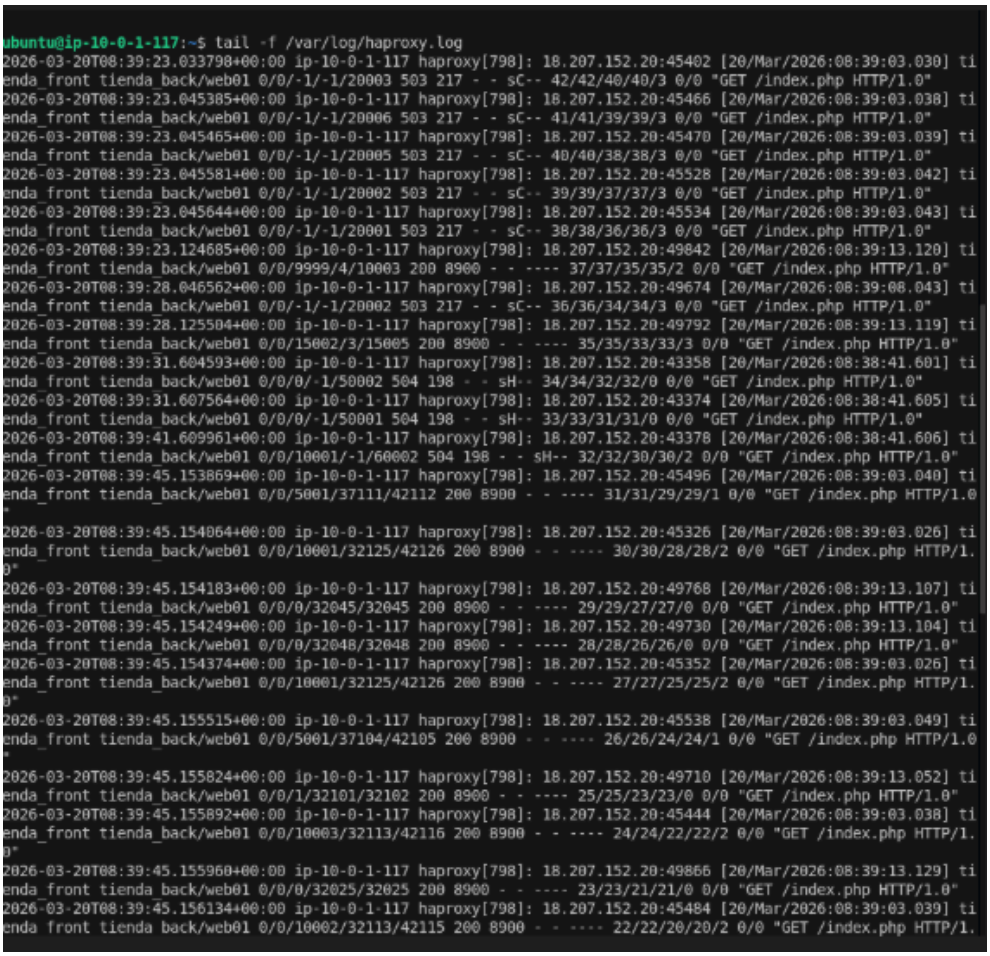
```
ubuntu@ip-10-0-1-233:~$ ab -n 5000 -c 50 http://34.234.93.231/index.php
This is ApacheBench, Version 2.3 <$Revision: 1903618 $>
Copyright 1996 Adam Twiss, Zeus Technology Ltd, http://www.zeustech.net/
Licensed to The Apache Software Foundation, http://www.apache.org/

Benchmarking 34.234.93.231 (be patient)
Completed 500 requests
Completed 1000 requests
Completed 1500 requests
Completed 2000 requests
Completed 2500 requests
Completed 3000 requests
Completed 3500 requests
Completed 4000 requests
Completed 4500 requests
Completed 5000 requests
Finished 5000 requests


Server Software:        Apache/2.4.66
Server Hostname:        34.234.93.231
Server Port:            80

Document Path:          /index.php
Document Length:        8584 bytes

Concurrency Level:      50
Time taken for tests:   105.082 seconds
Complete requests:      5000
Failed requests:        748
   (Connect: 0, Receive: 0, Length: 748, Exceptions: 0)
Non-2xx responses:      748
Total transferred:      38169206 bytes
HTML transferred:       36578454 bytes
Requests per second:    47.58 [#/sec] (mean)
Time per request:       1050.822 [ms] (mean)
Time per request:       21.016 [ms] (mean, across all concurrent requests)
Transfer rate:          354.72 [Kbytes/sec] received

Connection Times (ms)
              min  mean[+/-sd] median   max
Connect:        0    1   0.9      1       9
Processing:     0  869 6112.0     25   65006
Waiting:        0  868 6112.1     23   65006
Total:          1  870 6111.9     26   65007

Percentage of the requests served within a certain time (ms)
  50%     26
  66%     31
  75%     35
  80%     38
  90%     51
  95%     67
  98%  10085
```

Resultado de la prueba de 5000 peticiones concurrentes.

Impacto en la base de datos MariaDB durante las ráfagas de peticiones.

5. Gestión de Cambios e Incidencias

Fecha	Incidencia	Resolución
16/03/2026	Agente Wazuh Disconnected	Corrección de sintaxis XML en /var/ossec/etc/ossec.conf.
16/03/2026	Loki WAL Error	Reconfiguración de permisos en el volumen Docker de logs.
16/03/2026	Error 403 Wazuh-Indexer	Cambio de binding a 0.0.0.0 y apertura de puerto 9200.
20/03/2026	Simulación Brute Force	Detección exitosa de alerta Nivel 10 en Wazuh/Grafana.
17/03/2026	Detección de CVE Crítico (OpenSSL)	Wazuh alertó de una vulnerabilidad en la librería libssl. Se procedió a actualizarla mediante apt-get upgrade en todos los servidores web.
20/03/2026	Fallo de Resolución de Nombres (Docker Host Mode)	Los contenedores de monitorización no podían comunicarse entre sí. Se sustituyeron los nombres de servicio por localhost en los ficheros de configuración.



```
ubuntu@ip-10-0-1-117:~$ tail -f /var/log/haproxy.log
2026-03-20T08:39:23.033798+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45402 [20/Mar/2026:08:39:03.030] ti
enda_front tienda_back/web01 0/0/-1/-1/20003 503 217 - - sC-- 42/42/40/40/3 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:23.045385+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45466 [20/Mar/2026:08:39:03.038] ti
enda_front tienda_back/web01 0/0/-1/-1/20006 503 217 - - sC-- 41/41/39/39/3 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:23.045465+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45470 [20/Mar/2026:08:39:03.039] ti
enda_front tienda_back/web01 0/0/-1/-1/20005 503 217 - - sC-- 40/40/38/38/3 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:23.045581+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45528 [20/Mar/2026:08:39:03.042] ti
enda_front tienda_back/web01 0/0/-1/-1/20002 503 217 - - sC-- 39/39/37/37/3 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:23.045644+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45534 [20/Mar/2026:08:39:03.043] ti
enda_front tienda_back/web01 0/0/-1/-1/20001 503 217 - - sC-- 38/38/36/36/3 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:23.124685+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:49842 [20/Mar/2026:08:39:13.120] ti
enda_front tienda_back/web01 0/0/9999/4/10003 200 8900 - - ---- 37/37/35/35/2 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:28.046562+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:49674 [20/Mar/2026:08:39:08.043] ti
enda_front tienda_back/web01 0/0/-1/-1/20002 503 217 - - sC-- 36/36/34/34/3 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:28.125504+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:49792 [20/Mar/2026:08:39:13.119] ti
enda_front tienda_back/web01 0/0/15002/3/15005 200 8900 - - ---- 35/35/33/33/3 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:31.604593+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:43358 [20/Mar/2026:08:38:41.601] ti
enda_front tienda_back/web01 0/0/0/-1/50002 504 198 - - sH-- 34/34/32/32/0 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:31.607564+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:43374 [20/Mar/2026:08:38:41.605] ti
enda_front tienda_back/web01 0/0/0/-1/50001 504 198 - - sH-- 33/33/31/31/0 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:41.609961+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:43378 [20/Mar/2026:08:38:41.606] ti
enda_front tienda_back/web01 0/0/10001/-1/60002 504 198 - - sH-- 32/32/30/30/2 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:45.153869+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45496 [20/Mar/2026:08:39:03.040] ti
enda_front tienda_back/web01 0/0/5001/37111/42112 200 8900 - - ---- 31/31/29/29/1 0/0 "GET /index.php HTTP/1.0
"
2026-03-20T08:39:45.154064+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45326 [20/Mar/2026:08:39:03.026] ti
enda_front tienda_back/web01 0/0/10001/32125/42126 200 8900 - - ---- 30/30/28/28/2 0/0 "GET /index.php HTTP/1.
0"
2026-03-20T08:39:45.154183+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:49768 [20/Mar/2026:08:39:13.107] ti
enda_front tienda_back/web01 0/0/0/32045/32045 200 8900 - - ---- 29/29/27/27/0 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:45.154249+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:49730 [20/Mar/2026:08:39:13.104] ti
enda_front tienda_back/web01 0/0/0/32048/32048 200 8900 - - ---- 28/28/26/26/0 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:45.154374+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45352 [20/Mar/2026:08:39:03.026] ti
enda_front tienda_back/web01 0/0/10001/32125/42126 200 8900 - - ---- 27/27/25/25/2 0/0 "GET /index.php HTTP/1.
0"
2026-03-20T08:39:45.155515+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45538 [20/Mar/2026:08:39:03.049] ti
enda_front tienda_back/web01 0/0/5001/37104/42105 200 8900 - - ---- 26/26/24/24/1 0/0 "GET /index.php HTTP/1.0
"
2026-03-20T08:39:45.155824+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:49710 [20/Mar/2026:08:39:13.052] ti
enda_front tienda_back/web01 0/0/1/32101/32102 200 8900 - - ---- 25/25/23/23/0 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:45.155892+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45444 [20/Mar/2026:08:39:03.038] ti
enda_front tienda_back/web01 0/0/10003/32113/42116 200 8900 - - ---- 24/24/22/22/2 0/0 "GET /index.php HTTP/1.
0"
2026-03-20T08:39:45.155960+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:49866 [20/Mar/2026:08:39:13.129] ti
enda_front tienda_back/web01 0/0/0/32025/32025 200 8900 - - ---- 23/23/21/21/0 0/0 "GET /index.php HTTP/1.0"
2026-03-20T08:39:45.156134+00:00 ip-10-0-1-117 haproxy[798]: 18.207.152.20:45484 [20/Mar/2026:08:39:03.039] ti
enda_front tienda_back/web01 0/0/10002/32113/42115 200 8900 - - ---- 22/22/20/20/2 0/0 "GET /index.php HTTP/1.
```

Logs en tiempo real con respuestas 200 y 503 durante el pico de carga.

6. Valoración Económica Final

La infraestructura se ha gestionado bajo el modelo de costes controlados de **AWS Academy**, utilizando un presupuesto total de **$50 de crédito**.

6.1. Análisis de Gasto Real (Marzo 2026)

A fecha de 20 de marzo de 2026, el panel de facturación de AWS muestra un **coste acumulado mensual de $2.29 USD**. Este incremento respecto a meses anteriores (donde el gasto era de apenas $0.07) se debe al despliegue simultáneo de las 5 instancias de la Fase 4.

Detalle del gasto acumulado en el dashboard de AWS Billing.

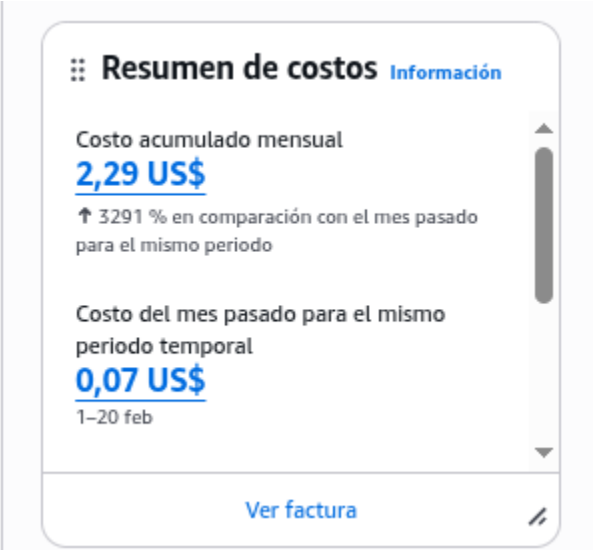
6.2. Desglose por Servicios

El gasto se distribuye principalmente en:

- **EC2 (Compute):** Instancias Web, DB, LB, Wazuh y Monitoring.
- **VPC / Networking:** Transferencia de datos y IPs elásticas.
- **CloudWatch:** Monitorización y almacenamiento de logs básicos.

6.3. Conclusión de Viabilidad

Incluso con el pico de actividad actual, el gasto proyectado mensual no supera los **$10 USD**, lo que garantiza que el proyecto es totalmente ejecutable dentro del margen de gratuidad académica, consumiendo menos del **25% del presupuesto anual** asignado.



Repositorio y Trazabilidad

- **Main Repo:** github.com/avrfpasir-jpg/tfg
- **Actividad:** [Commits y Gráficos]